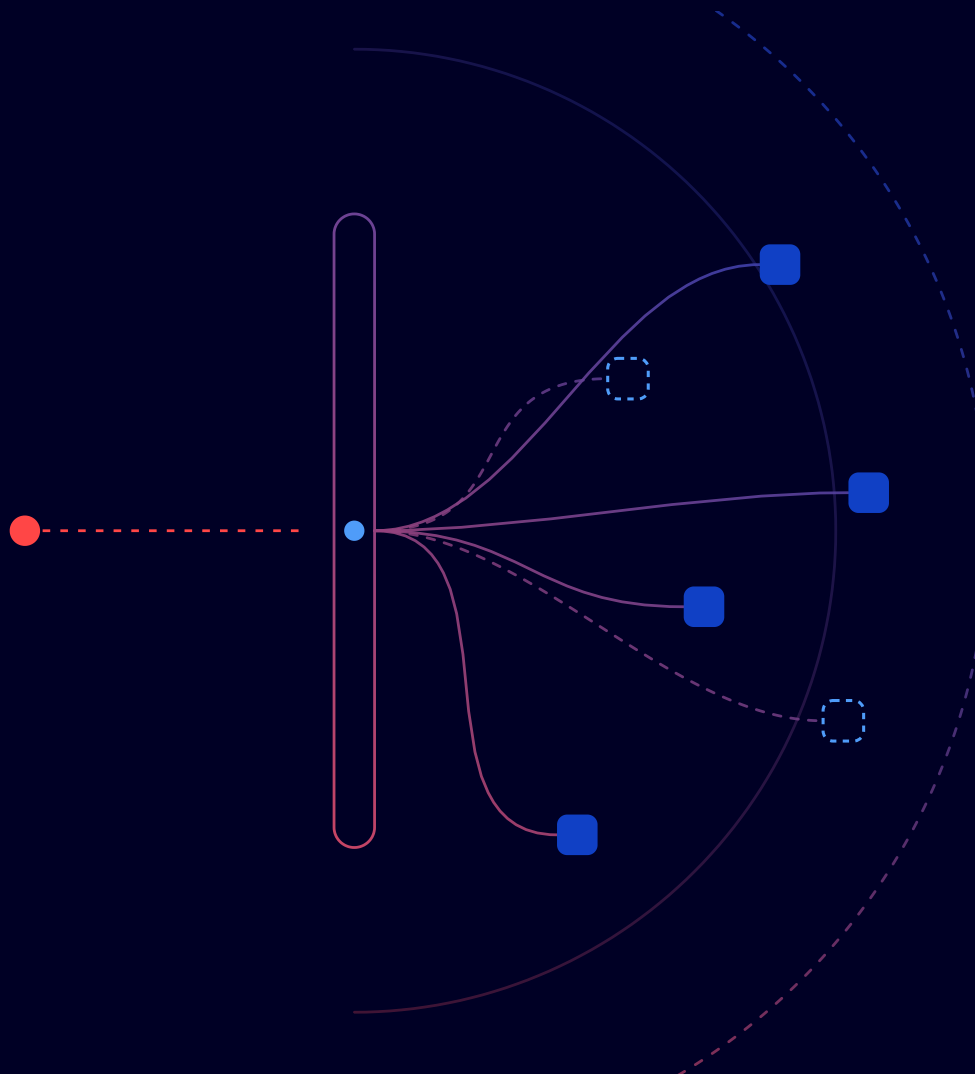
AccuKnox

Find every API before an attacker does

The do's and don'ts for six API security practices, from shadow API discovery to the ticket that closes each finding.



The problem

Attackers hit the APIs you never listed

Well over half of the dynamic traffic on the Cloudflare network is API traffic, per its 2024 API security report. Most teams cannot name every endpoint behind that traffic, so attacks land on routes nobody watches.

113%

rise in the average number of daily API attacks, year over year.

Akamai, 2026 Apps, APIs and DDoS SOTI report. akamai.com

30.7%

more API endpoints found by machine learning discovery than teams reported on their own.

Cloudflare, 2024 API Security and Management Report. blog.cloudflare.com

19%

of organizations are very confident that their API inventory is accurate.

Salt Security, H2 2025 State of API Security Report. salt.security

Root causes

Four gaps keep APIs exposed



The inventory lives in documents

54% of organizations rely on developer documentation to find sensitive data exposure. A route a developer ships on Friday is missing from that document on Monday.



Old versions keep answering

A V1 endpoint replaced by V2 can still take live calls, often with weaker authentication. OWASP lists this risk as API9:2023 Improper Inventory Management.



Nobody watches live traffic

80% of organizations lack continuous, real time API monitoring. A quarterly review misses the route a team added this week.



Findings have no owner

87% of organizations in the Akamai survey reported an API security incident in 2025. A finding with no ticket and no owner stays open until an attacker finds it.

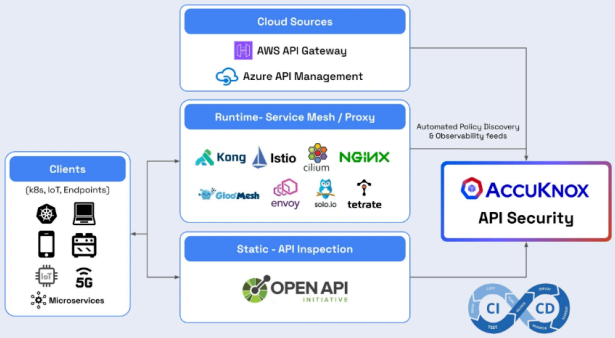
Sources: Salt Security, H2 2025 State of API Security Report, salt.security. OWASP API Security Top 10 2023, api-security.owasp.org. Akamai 2026 SOTI release, akamai.com.

Start here

Six practices close the API gap

Connect your gateways, set a specification baseline, then let AccuKnox compare the two. Each practice catches what the one before it misses.

Category	Support Details
Data Plane	API calls from users at North-South gate Inter-microservice calls using east-west traffic
Control Plane	K8s API Server AWS CloudTrail
K8s Support	On-prem and managed environments API Server visibility
Non-K8s Deployments	Leveraging ingress controllers like Nginx/Kong
AWS Data Plane	Using CloudTrail/CloudWatch App Mesh
Azure Data Plane	Static Functions, Web Apps
Google Data Plane	Anthos



API Security data sources, from cloud gateways and service meshes to OpenAPI specs.
help.accuknox.com/integrations/api-overview/

01 **Discover from live traffic** 05
Inventory every endpoint your gateways see

02 **Set a spec baseline** 06
Upload or generate the OpenAPI file

03 **Hunt shadow and zombie APIs** 07
Compare traffic to the spec

04 **Classify sensitive data** 08
Find keys, tokens and PII in traffic

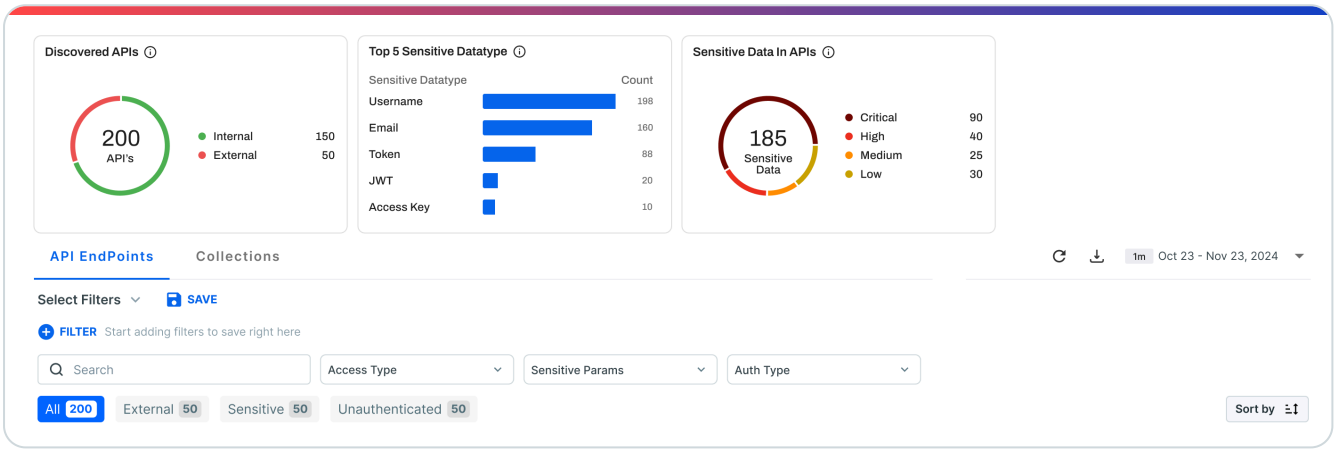
05 **Scan on a schedule** 09
Test the spec and the running API

06 **Route every finding** 10
Ticket, owner and rate limit

Practice 01

Build the inventory from live traffic

AccuKnox reads gateway and mesh logs and lists every endpoint it sees, with method, path, exposure and auth type.



API Security inventory with discovered APIs and sensitive data types. help.accuknox.com/use-cases/api-security/

DO

- Connect every gateway and mesh: AWS API Gateway, the K8s API proxy, Istio, NGINX, Kong and F5.
- Deploy the AWS API Gateway stack once per stage, so Dev, Staging and Prod all feed the inventory.
- Filter to External and Unauthenticated endpoints first, because attackers reach those.
- Group endpoints into collections by host, method or path regex, one per owning team.

DON'T

- Don't build the inventory from a wiki page or a gateway config export.
- Don't watch only the edge gateway. Service calls inside the mesh carry data too.
- Don't treat the inventory as a one time count. It changes as new logs arrive.

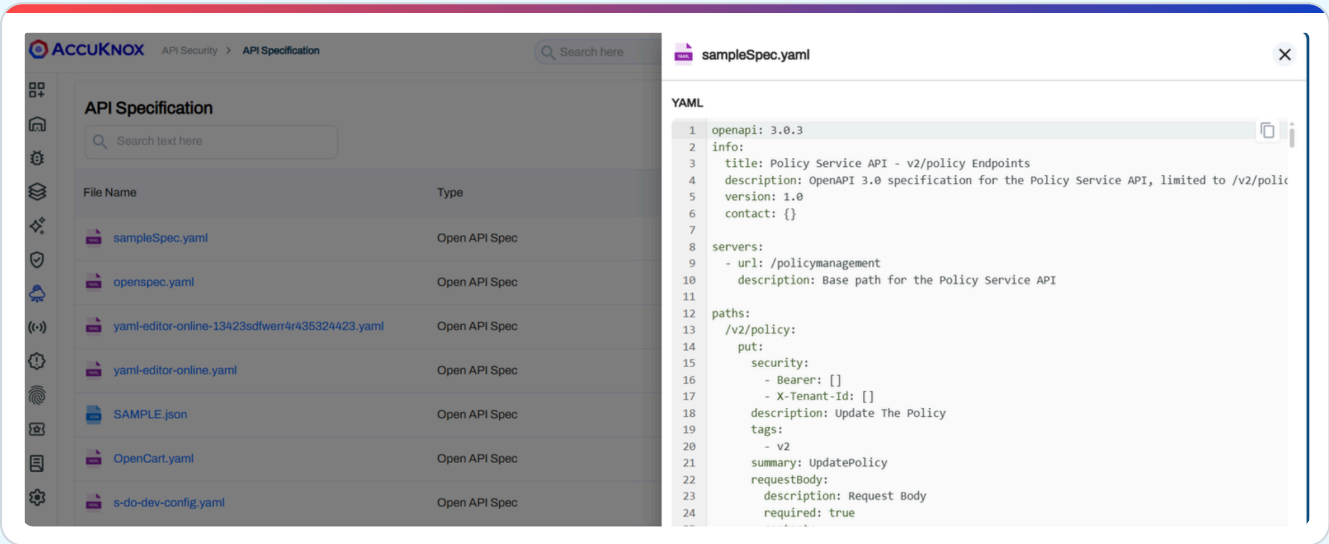
HOW ACCUKNOX CLOSES THE GAP

API Security builds the inventory from gateway logs with no code change, and creates a collection from each host endpoint on its own. Connect a traffic source

Practice 02

Make the OpenAPI spec your baseline

A scan compares observed endpoints against the spec, so the spec decides what counts as drift.



API Specification page with an OpenAPI 3.0 file open. help.accuknox.com/how-to/api-security-onboarding/

DO

- Upload every OpenAPI or Swagger file in JSON or YAML, up to 3 MB each.
- Generate a spec from observed traffic for any API that has none, then hand it to the owning team.
- Upload the new spec in the same release that changes the API.
- Rename a file before upload when you want to keep the old version.

DON'T

- Don't reuse an existing file name by accident. The upload replaces the old file.
- Don't trust a spec written once at launch. Routes change faster than documents.
- Don't skip the spec. The spec is the baseline that sorts Shadow from Active APIs.

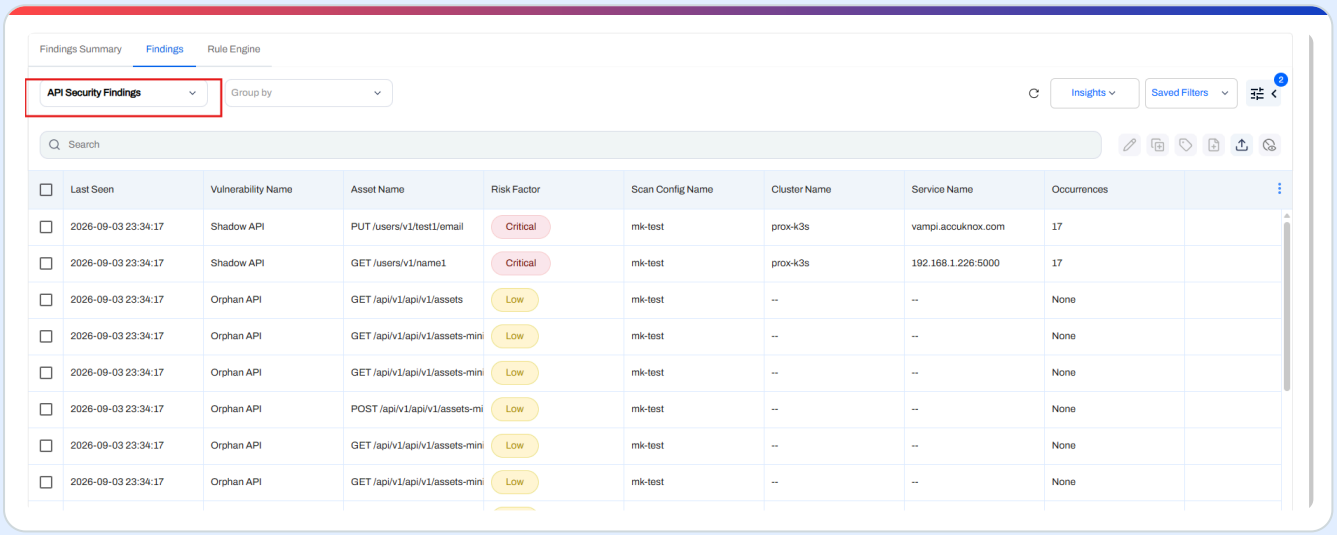
HOW ACCUKNOX CLOSES THE GAP

API Security stores each spec under API Security > API Specification, and generates an OpenAPI spec from traffic for an API with no documentation. Upload your first spec

Practice 03

Hunt shadow, zombie and orphan APIs

A spec scan sorts each endpoint into Shadow, Zombie, Orphan or Active, with request and response detail.



API Security Findings with Shadow API and Orphan API rows. help.accuknox.com/how-to/api-security-onboarding/

DO

- Triage Shadow APIs first. They take production traffic and no spec covers them.
- Retire each Zombie API, a deprecated version that still answers calls.
- Confirm each Orphan API with its owner, then remove it from the spec or the code.
- Scan per collection, so each team sees only its own drift.

DON'T

- Don't add a shadow endpoint to the spec before you check who calls it and what it returns.
- Don't leave a V1 route live after V2 ships.
- Don't read an empty Shadow list as safe while some gateways stay unconnected.

HOW ACCUKNOX CLOSES THE GAP

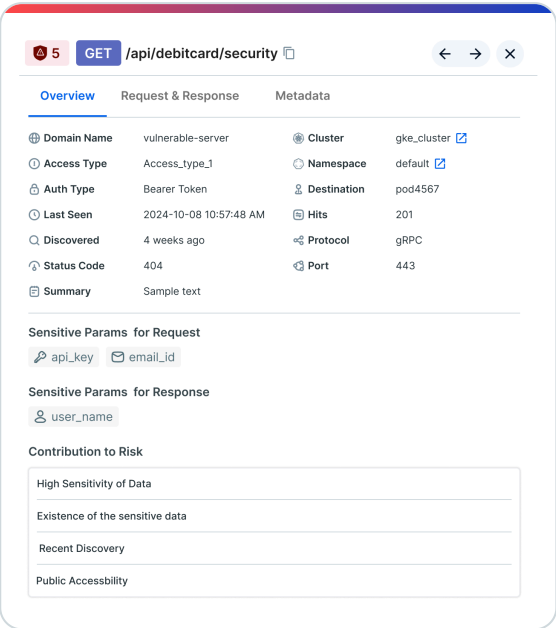
Shadow, zombie and orphan detection addresses OWASP API9:2023 Improper Inventory Management. Each finding shows the request, the response and the occurrence count. Read the finding types

Practice 04

Know which APIs carry sensitive data

Each endpoint lists the sensitive parameters AccuKnox found in its request and in its response.

The Contribution to Risk panel names why an endpoint ranks high, such as high sensitivity of data, recent discovery or public accessibility.



Endpoint detail with sensitive params and risk factors. help.accuknox.com/how-to/api-security-onboarding/

DO

- Filter the inventory by Sensitive Params such as api_key, password, token and JWT.
- Check the response, not only the request. A response can return data the caller never asked for.
- Raise priority when an endpoint is external, unauthenticated and sensitive at once.
- Review the Top 5 Sensitive Datatype chart every week for new data types.

DON'T

- Don't rely on developer notes to tell you which endpoints carry PII.
- Don't pass API keys or passwords in a query string or a URL path.
- Don't treat a Bearer token as enough when an endpoint returns another user's object. OWASP calls this API1:2023 Broken Object Level Authorization.

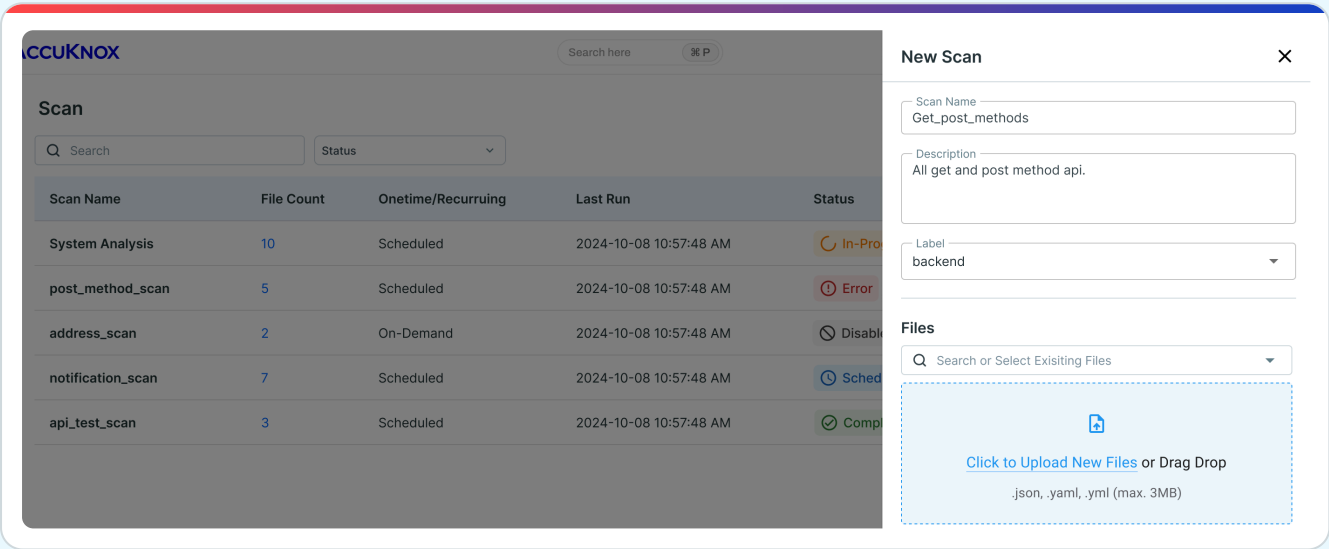
HOW ACCUKNOX CLOSES THE GAP

API Security classifies sensitive data in each request and response, and labels each endpoint as internal or external. Open endpoint telemetry

Practice 05

Scan on a schedule and test the live API

A spec scan finds drift. The API Scan collector sends active tests to a running target URL.



Scan list and the New Scan form. help.accuknox.com/how-to/api-security-onboarding/

DO

- Set each spec scan to Scheduled, so drift shows up without a reminder.
- Run both paths. The spec scan finds undocumented endpoints, and the collector finds weak responses.
- Point the API Scan collector at a staging target first, with a label and a notification email.
- Give each scan a label so findings group by team or service.

DON'T

- Don't expect a spec scan to find a source code disclosure. Only the collector tests live responses.
- Don't run active tests against production without the service owner's approval.
- Don't ignore a scan stuck at Error. Fix the file or the target, then rerun it.

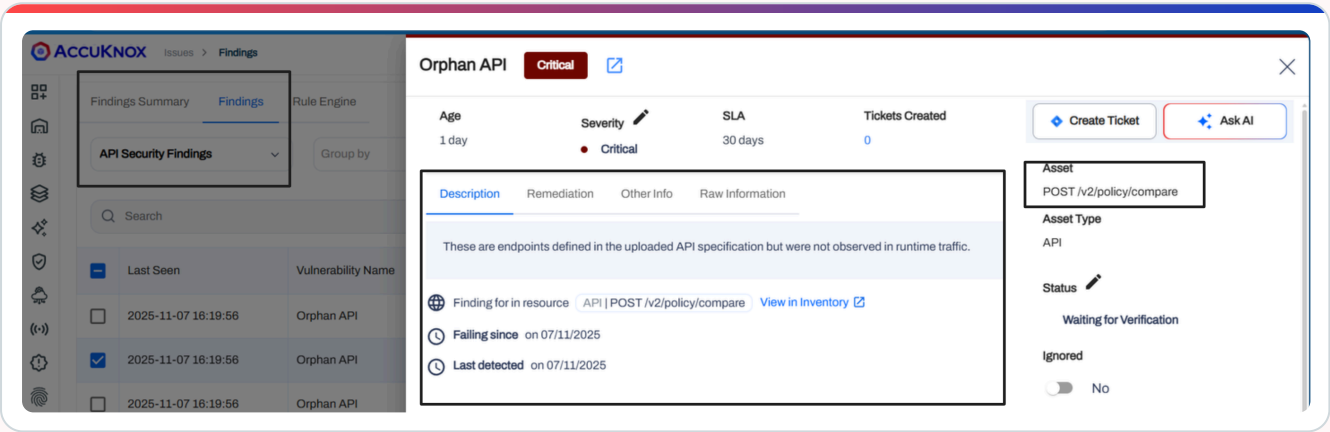
HOW ACCUKNOX CLOSES THE GAP

Spec scans run on demand or on a schedule. The API Scan collector takes its endpoints from an uploaded spec, a collection or a spec URL. Set up both scan paths

Practice 06

Route every finding to an owner

Each API finding opens with Create Ticket and Ask AI, and a Rules Engine rule can file the ticket for you.



Orphan API finding with Create Ticket and Ask AI. help.accuknox.com/use-cases/rules-engine-ticket-creation/

DO

- Write a Rules Engine rule that opens a Jira ticket for every Critical Shadow API.
- Use Ask AI on a finding to draft the fix for the owning team.
- Track the SLA and the status of each finding until the fix is verified.
- Rate limit login and checkout endpoints against API4:2023 Unrestricted Resource Consumption.

DON'T

- Don't let API findings land in a shared inbox nobody owns.
- Don't mark a finding as ignored without a note that says why.
- Don't start a new rate limit in Block. Run it as Alert first to learn normal traffic.

HOW ACCUKNOX CLOSES THE GAP

Rate limits apply per user or IP per endpoint, per user or IP across the app, or per service, with a Block or Alert action. Automate ticket creation

Gap check

Find your gap, then take the first step

Read each row. Where the gap is true for you, take the first step this week.

IF THIS IS TRUE	ACCUKNOX CAPABILITY	FIRST STEP
Nobody can list every API endpoint in production	API inventory	Connect your gateways and service mesh as traffic sources
Specs are missing or out of date	API Specification and spec generation	Upload the OpenAPI file, or generate one from traffic
Old API versions still answer calls	Shadow, zombie and orphan API detection	Run a spec scan on each collection
Nobody knows which APIs return PII or tokens	Sensitive data classification	Filter the inventory by Sensitive Params
APIs ship with no test against the running service	API Scan collector	Add the collector for one staging target
API findings sit in a queue with no owner	Rules Engine and rate limiting	Create a ticket rule for Critical API findings

AccuKnox

See every API you run in one inventory

Book a demo to see the inventory, the spec scan and the finding workflow in the AccuKnox console. Bring your gap check.

Book a demo | Read the API security docs

2026

KuppingerCole CNAPP Leadership Compass features AccuKnox Zero Trust CNAPP.

2

Best Practices recognitions in 2026, one global and one for Asia Pacific.

8

API traffic integrations, from AWS API Gateway to Azure API Management.

Sources: accuknox.com/analyst-recognition and help.accuknox.com/integrations/api-overview

accuknox.com · © 2026 AccuKnox, Inc.